



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-4873 connection reuse ignores TLS requirement

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-13
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-4873 connection reuse ignores TLS requirement - Vulnerability Report

Published: 2026-06-13 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CVE-2026-4873 curl / libcurl connection reuse ignores TLS requirement

1. Executive Summary

CVE-2026-4873 is a curl and libcurl information-disclosure flaw in connection reuse logic for mail-protocol traffic. The vendor advisory states that when an application first performs a clear-text transfer over `IMAP://`, `POP3://`, or `SMTP://`, a later transfer to the same host, with the same credentials and protocol, can incorrectly reuse that pre-existing unencrypted connection even when the later request requires TLS. In practice, this can cause credentials or message content that operators expected to protect with TLS to be sent in clear text.

The vulnerability is narrower than a typical internet-edge remote code execution issue. The curl project explicitly describes the trigger sequence as a special case and rates the flaw Low severity, while NVD enriches it as CVSS v3.1 5.9 / Medium because the confidentiality impact can be high once the preconditions are satisfied. The strongest operational risk exists where applications, scripts, or appliances use libcurl for mail retrieval or submission and mix insecure and TLS-required sessions to the same service endpoint.

This issue matters most to defenders because libcurl is often embedded invisibly inside automation, backup agents, monitoring connectors, email gateways, and business applications. Organizations may believe they have enforced TLS for mail collection or submission while still running a vulnerable version of curl/libcurl that can fall back into connection reuse behavior inconsistent with that expectation. Even if the flaw is unlikely to be mass-exploited opportunistically, it can still expose message data, credentials, or authentication material on untrusted networks.

The primary remediation path is straightforward: upgrade to curl/libcurl 8.20.0 or apply an equivalent vendor backport, then review workflows that still permit clear-text IMAP, POP3, or SMTP activity. Detection and hunting should focus on exposure identification, mail-protocol usage by curl-based tooling, and mixed clear-text/TLS mail sessions from the same process or host rather than on traditional IOC matching.

2. Intelligence Requirement

This report addresses the following intelligence requirement: what does CVE-2026-4873 mean for defenders using curl or libcurl in mail-related workflows, which environments are meaningfully exposed, how credible is exploitation, and what immediate remediation, detection, and hunting actions should be prioritized?

Question	Assessment
What is the flaw?	TLS-required mail transfers can incorrectly reuse an existing non-TLS connection from the same libcurl connection pool.
Which protocols matter?	`IMAP://`, `POP3://`, and `SMTP://` only, per the curl advisory.
What must happen first?	An initial clear-text transfer must already occur, then a later TLS-required request must target the same host, credentials, and protocol.
What is the primary impact?	Confidentiality loss: credentials or message data intended for protected transit may instead travel unencrypted.
Which versions are affected?	curl/libcurl 7.20.0 through 8.19.0, fixed in 8.20.0 according to the vendor advisory and NVD enrichment.
Is active exploitation confirmed?	No authoritative evidence of in-the-wild exploitation was identified in the reviewed vendor, NVD, Openwall, Debian, or MSRC-linked material.
Which environments deserve highest priority?	Systems and applications using libcurl for email ingestion or submission, especially where clear-text and TLS-required mail sessions can target the same host over untrusted or shared

	networks.
--	-----------

3. Source Review and Confidence

Source	Contribution	Confidence
curl security advisory (`CVE-2026-4873.html`)	Canonical flaw description, protocol scope, affected versions, fixed version, and mitigation guidance	High
curl JSON advisory (`CVE-2026-4873.json`)	Machine-readable affected-version ranges, CWE mapping, publication timeline, and fix commit references	High
NVD CVE record	CVSS 3.1 vector, CPE range, and reference consolidation	High
Debian Security Tracker	Downstream packaging status and evidence that multiple maintained distro branches still tracked the issue as vulnerable at review time	High
Openwall oss-security advisory post	Independent republication of the upstream advisory and disclosure timeline context	High
Microsoft Security Update Guide intake item	Discovery path for this workflow; useful as syndication context only, not as the primary technical source	Medium

Assessment confidence is high for the core technical conclusions because the vendor advisory, vendor JSON, NVD enrichment, Debian tracking, and Openwall republication all align on the same trigger sequence and affected version range. Confidence is medium for exploitation prevalence because the reviewed public sources did not provide authoritative incident reporting, KEV inclusion, or confirmed campaign use.

Two caveats matter for defenders. First, the issue is materially constrained by preconditions: it affects only IMAP, POP3, and SMTP transfers, and the same host, credentials, and protocol must be reused after an initial clear-text session. Second, version strings alone are not always sufficient for triage because downstream Linux vendors may ship backported fixes without matching upstream version numbering exactly; vendor package advisories should be checked before concluding a host remains exposed.

4.1 Vulnerability metadata

Field	Value
CVE	CVE-2026-4873
Product family	curl and libcurl
Vulnerable behavior	Reuse of an existing clear-text mail connection when a later transfer requires TLS
Affected protocols	`IMAP://`, `POP3://`, `SMTP://`
Weakness	Vendor: CWE-319 Cleartext Transmission of Sensitive Information; NVD also lists CWE-295 in enrichment
Vendor severity	Low

NVD severity	CVSS v3.1 5.9 / Medium
CVSS vector	`AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N`
Affected versions	curl/libcurl 7.20.0 through 8.19.0
Fixed version	curl/libcurl 8.20.0
Introduced by	curl commit `ec3bb8f727405642a471b4b1b9eb0118fc003104`
Fixed by	curl commit `507e7be573b0a76fca597b75ff7cb27a66e7d865`
Primary impact	Confidentiality loss through unintended unencrypted transmission
Exploitation status	No authoritative in-the-wild exploitation confirmation found during this review

4.2 Flaw mechanics

The defect sits in connection-pool reuse logic rather than certificate parsing or TLS cryptography itself. According to the curl advisory, if an initial IMAP, POP3, or SMTP transfer is performed in clear text, a later request to the same host that requires TLS can reuse the already-open unencrypted connection instead of establishing a properly protected session. This means the client-side expectation of TLS is violated by state reuse rather than by an outright TLS downgrade prompt or user override.

Operationally, that makes this a workflow and implementation risk rather than a universal protocol break. An application or script must already permit clear-text mail traffic under some conditions, then later attempt to upgrade or enforce TLS while still benefiting from pooled connection reuse. Environments that never permit non-TLS mail connections are less exposed than environments that support mixed legacy and modern mail modes against the same server estate.

4.3 Exposure profile

Exposure pattern	Why it matters	Priority
Applications embedding libcurl for inbound or outbound mail workflows	Many operators do not realize libcurl is present inside higher-level software, making exposure easy to miss	Immediate
Automation that mixes legacy clear-text mail polling with newer TLS-required mail sessions	Precisely matches the vendor-described trigger sequence	Immediate
Hosts traversing shared, partner, hotel, ISP, or other untrusted networks	Clear-text leakage becomes materially more dangerous where network observers can capture traffic	High
Email gateways, monitoring collectors, backup/archival systems, and notification tooling using SMTP/IMAP/POP3 through libcurl	Often run unattended and may retain long-lived connection pools	High
Environments using vendor-backported packages without strong asset metadata	Version-based detection may misclassify systems as exposed or safe	Medium
Web-only curl usage without IMAP/POP3/SMTP functionality	Outside the described protocol scope	Reduced

4.4 Defensive meaning and ATT&CK mapping

The ATT&CK mapping for this CVE should remain narrow because the vulnerability is a transport-protection failure rather than an intrusion set or malware family. Where mapping is useful, it centers on confidentiality loss from network-observable clear-text traffic.

ATT&CK ID	Technique	Rationale
T1040	Network Sniffing	If attackers can observe the network path, the flaw can expose credentials or email content that operators expected to protect with TLS.
T1557	Adversary-in-the-Middle	The issue can increase the value of on-path interception where an adversary can monitor or manipulate mail traffic on untrusted networks.
T1071.003	Application Layer Protocol: Mail Protocols	The affected protocols are SMTP, POP3, and IMAP, which define the vulnerable operational surface.

4.5 Validation status

No local exploit reproduction or packet-capture lab validation was performed during this task. This report is based on reviewed vendor and downstream public sources. Confidence is high in the scope and remediation guidance, but medium regarding real-world exploitation prevalence because reviewed sources did not include authoritative campaign reporting.

5. Threat Context

CVE-2026-4873 is best understood as a confidentiality and trust-boundary problem in mail-enabled clients and integrations. It is less attractive for indiscriminate internet-scale exploitation than a pre-authentication RCE, but it is still operationally important because mail credentials, message content, or workflow metadata may traverse the network in clear text after defenders believed TLS was required.

The issue is especially relevant in transitional environments that still support older clear-text mail workflows for compatibility reasons. A team may have partially modernized by requiring TLS for some transactions while retaining non-TLS connectivity for others to the same mail server or relay. That coexistence, combined with vulnerable connection-pool reuse, creates the opportunity for a later transfer to inherit the wrong security state.

5.1 Representative attack and failure scenarios

Scenario	Description	Defensive meaning
Mixed-mode mail automation	A scripted integration first talks clear-text IMAP/POP3/SMTP to a legacy endpoint, then later expects a TLS-protected session to the same host using the same credentials	Review application logic, not just perimeter controls
On-path observation	An adversary on a shared or untrusted network captures credentials or message content because a transfer silently rides an unencrypted reused connection	Prioritize upgrades on mobile, branch, and partner-connected assets
Embedded dependency blind spot	A business application uses vulnerable libcurl internally, but asset owners only inventory the top-level application and never evaluate bundled libraries	Inventory SBOM and package dependencies, not just installed binaries

False sense of encryption assurance	Operators believe a TLS-required configuration guarantees protected transport, while vulnerable reuse behavior undermines that assumption under a specific sequence	Validate secure mail workflows in testing and packet capture where feasible
-------------------------------------	---	---

5.2 Exploitation-status assessment

The reviewed public record does not support a high-confidence claim of active exploitation. The curl project describes the trigger as an unusual sequence of events and rates the issue Low severity; Debian notes it as a minor issue in multiple branches; and the reviewed NVD/Openwall/MSRC-linked material did not cite confirmed campaigns or urgent KEV-style prioritization. That should lower panic, but not eliminate action: the flaw can still expose sensitive content in environments where mail traffic crosses networks that defenders do not fully trust.

5.3 Exposure-reduction priorities

Exposure driver	Why it increases risk	Defensive priority
Support for clear-text IMAP/POP3/SMTP	Supplies the initial insecure session required for the flaw to matter	Highest
Reuse of the same host and credentials across mixed secure/insecure mail workflows	Matches the precise trigger sequence described by the vendor	Highest
Long-lived mail polling or submission daemons using libcurl	Increases the chance that pooled connections persist across workflow changes	High
Limited software inventory for bundled libcurl usage	Leaves vulnerable dependencies hidden inside other tools	High
Reliance on network trust instead of enforced transport controls	Makes confidentiality loss more plausible on shared or partner networks	Medium

6. Detection and Hunting

This CVE is better suited to exposure management and behavior hunting than to classic signature-based detection. There are no stable malware IOCs in the reviewed sources. Defenders should instead identify vulnerable curl/libcurl versions, locate applications using mail protocols through curl-based tooling, and hunt for mixed clear-text and TLS mail sessions or unexpected use of legacy mail ports.

6.1 Detection coverage summary

Signal	Telemetry source	Analytic goal	Coverage caveat
Installed curl/libcurl version below fixed or backported level	Package inventory, EDR software inventory, SBOM data	Find systems that may still contain vulnerable code	Requires vendor-backport awareness
Process usage of `curl` or `curl.exe` with `imap://`, `pop3://`, or `smtp://` URLs	EDR process creation logs, shell audit, command history	Identify workflows that exercise the affected protocol surface	Misses embedded libcurl use without obvious CLI invocation
Network connections to mail ports 25/110/143 followed by 465/993/995 from the same process or host	Network telemetry, EDR socket events, firewall logs	Surface mixed secure/insecure mail workflows consistent with the vulnerability preconditions	Not a direct exploitation confirmation
Authentication or message	Packet capture, TLS inspection,	Confirm real confidentiality	Often unavailable outside

transfer over clear text where TLS was expected	mail gateway logs	exposure	focused troubleshooting
---	-------------------	----------	-------------------------

6.2 Sigma - mail-protocol curl usage on endpoints

```

title: curl Mail Protocol Usage That May Require CVE-2026-4873 Exposure Review
id: 3f7bc27a-0b79-4f3d-a2fd-8b16b46ad68d
status: experimental
description: Detects curl or curl.exe process executions that reference IMAP, POP3, or SMTP URLs and may warrant review for vulnerable mixed clear-text and TLS mail workflows related to CVE-2026-4873.
author: Lost Boys Cyber
date: 2026-06-13
references:
  - https://curl.se/docs/CVE-2026-4873.html
  - https://nvd.nist.gov/vuln/detail/CVE-2026-4873
logsource:
  category: process_creation
  product: windows
detection:
  image:
    Image|endswith:
      - '\curl.exe'
      - '\curl.exe.mui'
  cmd_mail:
    CommandLine|contains:
      - 'imap:/'
      - 'pop3:/'
      - 'smtp:/'
  condition: image and cmd_mail
falsepositives:
  - Legitimate mail troubleshooting or automation using curl
  - Security-team validation activity
level: medium
tags:
  - attack.t1071.003
  - attack.t1040

```

Linux estates should adapt the same logic to `Image|endswith: '/curl'` and relevant shell or EDR telemetry fields.

6.3 KQL - inventory potentially exposed curl usage

```

let lookback = 30d;
let mailProcesses = DeviceProcessEvents
| where Timestamp > ago(lookback)
| where FileName in~ ("curl", "curl.exe")
| where ProcessCommandLine has_any ("imap:/", "pop3:/", "smtp:/")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine;
let mailConnections = DeviceNetworkEvents
| where Timestamp > ago(lookback)
| where RemotePort in (25, 110, 143, 465, 993, 995)
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, RemoteIP, RemoteUrl, RemotePort, Protocol;
mailProcesses
| join kind=leftouter (
  mailConnections
  | where InitiatingProcessFileName in~ ("curl", "curl.exe")
) on DeviceName
| where Timestamp1 between (Timestamp .. Timestamp + 30m)
| order by Timestamp desc

```

6.4 KQL - software inventory triage

```

DeviceTvmSoftwareInventory
| where SoftwareName has_any ("curl", "libcurl")
| project DeviceName, SoftwareName, SoftwareVersion, Vendor
| order by DeviceName asc, SoftwareName asc

```


6.5 Threat-hunting hypotheses

Hypothesis	What to prove or disprove
Some applications still permit clear-text IMAP/POP3/SMTP traffic even though administrators believe TLS is mandatory	Review configs, process telemetry, and network logs for legacy mail-port usage
Vulnerable libcurl is embedded inside third-party software that asset owners do not track directly	Cross-reference package inventory, SBOM data, and application dependency manifests
Mixed clear-text and TLS mail sessions to the same host occur from the same endpoint or process	Hunt for port 25/110/143 activity followed by 465/993/995 to the same destination within a short window
Exposure is concentrated on automation and service accounts rather than end-user workstations	Identify scheduled jobs, collectors, gateways, and backend integrations that use curl-based mail functionality

No stable domains, hashes, or attacker infrastructure indicators were identified from the reviewed sources. Treat this as a vulnerability-management and workflow-validation problem, not an IOC-led threat hunt.

7. Recommendations

Priority	Owner	Action	Rationale
Immediate	Platform / endpoint engineering	Upgrade curl and libcurl to 8.20.0 or deploy vendor backports that remediate CVE-2026-4873	Removes the flawed connection-reuse behavior
Immediate	Application owners	Identify every workflow that uses IMAP, POP3, or SMTP through curl/libcurl, including embedded dependencies	The affected surface is protocol-specific and often hidden inside applications
Immediate	Messaging / infrastructure teams	Disable or phase out clear-text mail protocols where business operations allow	Eliminates the insecure precondition required by the flaw
High	Security engineering	Add inventory and hunt coverage for mail-protocol curl usage and mixed legacy/TLS mail sessions	Best available way to locate practical exposure
High	QA / DevOps	Validate mail integrations that change between insecure and TLS-required states against the same host credentials	Prevents silent assumption drift in integration code
Medium	Network engineering	Prioritize remediation for systems that use mail workflows across partner, branch, cloud, or otherwise less-trusted network paths	Reduces the chance that clear-text leakage is observable
Medium	Vulnerability management	Account for distro backports when triaging Linux package versions	Prevents false positives and false negatives in remediation reporting
Low	Architecture / modernization	Prefer mail libraries and workflows that enforce TLS-	Reduces reliance on mixed-mode legacy compatibility over

		only transport with clear testing and telemetry	time
--	--	---	------

Recommended execution order:

- 1. Inventory curl/libcurl versions and mail-protocol usage across applications and automation.
- 2. Patch or backport affected systems, prioritizing hosts that still permit clear-text IMAP/POP3/SMTP.
- 3. Validate that mixed-mode mail workflows no longer rely on insecure sessions or silent TLS assumptions.
- 4. Hunt for legacy mail-port usage and mixed clear-text/TLS behavior to the same destinations.
- 5. Remove or quarantine clear-text mail dependencies wherever the business can tolerate the change.

8. References

- 1. curl Security Advisory, `CVE-2026-4873: connection reuse ignores TLS requirement` - <https://curl.se/docs/CVE-2026-4873.html>
- 2. curl machine-readable advisory JSON, `CVE-2026-4873.json` - <https://curl.se/docs/CVE-2026-4873.json>
- 3. NVD CVE record, `CVE-2026-4873` - <https://nvd.nist.gov/vuln/detail/CVE-2026-4873>
- 4. Debian Security Tracker, `CVE-2026-4873` - <https://security-tracker.debian.org/tracker/CVE-2026-4873>
- 5. Openwall oss-security advisory mirror, `[ADVISORY] curl: CVE-2026-4873: connection reuse ignores TLS requirement` - <https://www.openwall.com/lists/oss-security/2026/04/29/7>
- 6. Microsoft Security Update Guide syndication entry - <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-4873>